

Lab #8 - Assessment Worksheet

Performing a Web Site and Database Attack by Exploiting Identified Vulnerabilities

Course Name and Number:

202170 CYBS-5F70-7QA

Student Name:

Christopher Phan

Instructor Name:

Karen Winters

Lab Due Date:

10/26/2021

Lab Assessment Questions & Answers

1. Why is it critical to perform a penetration test on a web application and a web server prior to production implementation?

It is critical to run a penetration test as it helps uphold the pillars of cybersecurity: confidentiality, integrity, and availability. With a penetration test, it assesses if a website is capable of upholding those three. This is absolutely necessary as this website might hold customer's vital data and as well as hundreds of payment information through e-commerce, such as credit card, login data, PII.

2. What is a cross-site scripting attack? Explain in your own words.

What a cross-site scripting attack is type of injection attack that hackers use to input malicious code through a website, and modifying or extracting data on the website, and then the users would unconsciously execute the code, allowing it to wreck havoc onto the website through corruption and stealing user identities or site visitors. This can be done through a coding flaw of the website, using the client software as the vector.

3. What is a reflective cross-site scripting attack?

A reflective cross-site scripting attack is a non-persistent attack that is not as serious as its counterpart but much more common, is when the hackers use scripting onto the URL directly or by device, and try to put themselves in a position of power in the system, brute forcing themselves to be shown user's data or data that would be desirable for some form of gain and having privileges on the victim's server.

4. Which web application attack is more likely to extract privacy data elements out of a database?

The web application attack that would most likely extract privacy data elements out of a database is a stored cross-site scripting attack.

5. What security countermeasures could be used to monitor your production SQL databases against injection attacks?

Security countermeasures to monitor injection attacks is through the DMWA application, which is a tool that is intentionally left extremely vulnerable to aid on any changes to a server or website and see if any scripting or abnormal changes have been made in the SQL databases.

6. What can you do to ensure that your organization incorporates penetration testing and web application testing as part of its implementation procedures?

By showing how common they are, and as well the consequences if we do not take proper steps to mitigate the chances of such attacks happening. If we did not incorporate penetration tests to our web application, we would have no idea how vulnerable our website is actually is and no idea how much information could be leaking from us, as well as how many customers we have endangered. I would warn about all the exploits that can happen from cross scripting attacks and what could be injected to our scripting without any of our knowledge and how all of our most valuable data be bleeding out of company, and that does not include the legal trouble we would have from not taking enough precautions to protect our customers.

7. Who is responsible for the CIA of production web applications and web servers?

The one responsible of upholding CIA for the website application and servers are the developers, as they are ones in charge of coding and scripting the entirety of it, as such they are the ones who must uphold the CIA for all users and customers of the web application and server since they are the ones who conduct the penetration test on their own creation.

8. In Part 2 of the lab, DVWA revealed the user name that was used to make inquiries on the server. What was that user name?

root